DevSecOps

Mikel Egaña Aranguren

mikel-egana-aranguren.github.io

mikel.egana@ehu.eus

Universidad del País Vasco
Euskal Herriko Unibertsitatea
BILBOKO INGENIARITZA ESKOLA
ESCUELA DE INGENIERÍA DE BILBAO

DevSecOps

https://doi.org/10.5281/zenodo.4302267

https://github.com/mikel-egana-aranguren/EHU-SGSSI-01



DevSecOps

- Segurtasuna (Sec) softwarearen bizi-zikloan (Dev) eta operazioetan (Ops) integratzen du
- Garatzaileek, operazioek eta segurtasunak erantzukizuna partekatzen dute
- Egiaztapenak automatizatzen ditu feedback esplizitua, goiztiarra eta jarraia lortzeko

Helburuak eta printzipioak

- Segurtasuna diseinutik bertatik txertatu, ez soilik argitaratu aurretik
- Errepikagarriak diren kontrolak automatizatu lan-fluxuaren barruan
- Gutxieneko pribilegioa aplikatu eta datuak zein kredentzialak babestu
- Aurkikuntzak feedback gisa tratatu, etengabe hobetzeko

Segurtasuna bizi-zikloan

- Plangintza: segurtasun-eskakizunak eta mehatxuen analisia
- Garapena: kode-berrikuspena eta analisi automatizatuak
- Integrazioa eta entrega: dependentzien eta artefaktuen balidazioa
- Zabalkuntza eta operazioa: konfigurazio segurua, monitorizazioa eta erantzuna

Shift left eta etengabeko feedbacka

Aldaketa txertatzen den unetik hurbil arazoak detektatzeak konpontzeko kostua murrizten du.

- Egiaztapenak garapen-ingurunean eta aldaketa bakoitzean exekutatu
- Emaitza argiak eta lehentasunak workflow-aren barruan erakutsi
- Kontrolak produkzioan ere mantendu: segurtasuna ez da zabaltzean amaitzen

Eskakizunak eta mehatxuen modelatzea

- Aktiboak, erabiltzaileak, zerbitzuak eta konfiantza-mugak identifikatu
- Sistemarentzat garrantzitsuak diren mehatxuak eta arriskuak deskribatu
- Arintze-neurriak definitu eta egiaztagarriak diren eskakizun bihurtu
- Arkitektura edo mendekotasunak aldatzen direnean analisia berrikusi

Kodearen segurtasuna

- Kode-berrikuspena eta onarpen-irizpide partekatuak
- SAST (Static Application Security Testing): iturburu-kodea aplikazioa exekutatu gabe analizatzea
- DAST (Dynamic Application Security Testing): aplikazioa exekuzioan dagoen bitartean ebaluatzea
- Sekretuen eskaneatzea, kredentzialak argitaratzea saihesteko

Mendekotasunak eta hornikuntza-katea

- Osagaien eta bertsioen inbentarioa mantendu (SBOM)
- Dependentziak analizatu eta zaurgarritasunak arriskuaren arabera lehenetsi
- Osagaiak eguneratu eta artefaktuen jatorria egiaztatu
- Biltegi eta eraikitze-prozesu kontrolatuak erabili

SBOM: Software Bill of Materials

- Proiektu batean erabilitako software-osagai guztiak dokumentatu
- Trazabilitatea eta zaurgarritasunen kontrola erraztu
- Gardentasuna eta arrisku-kudeaketa hobetu
- Auditoria eta araudi-betetzea erraztu

SBOM: Software Bill of Materials

- CycloneDX: SBOM adierazteko formatu estandarra (OWASP)
- Mikel Egaña Aranguren, Jesualdo Tomás Fernández-Breis, Bidane Leon Balentzia, Markus Rompe, Alexander García Castro. A comprehensive view of software vulnerability risks through enterprise knowledge graphs. Computers & Security 2026: 163 (104815)

Segurtasuna CI/CDn

- CI/CD: Continous Integration / Continuous Delivery
- Adarrak, berrikuspenak eta exekuzio-baimenak babestu
- Zeregin bakoitzaren baimenak beharrezkoenera mugatu
- Kredentzial iraunkorrak saihestu eta kodean sekreturik ez sartu
- Argitaratutako artefaktuen jatorria balidatu eta mantendu

Edukiontziak eta infraestruktura kode gisa

- Infraestruktura kode gisa definitu eta bertsionatu (Ansible examples)
- Mantendutako oinarrizko irudiak erabili eta beharrezkoak ez diren osagaiak murriztu
- Zerbitzuak gutxieneko baimenekin eta konfigurazio esplizituarekin exekutatu
- Irudiak analizatu eta azpiegituraren aldaketak zabaldu aurretik berrikusi
- Sekretuak irudietatik eta bertsionatutako fitxategietatik kanpo kudeatu

Zabalkuntza eta operazioa

- Konfigurazio seguruak aplikatu eta produkzioko aldaketak kontrolatu
- Garrantzitsuak diren gertaerak erregistratu eta erregistroak babestu
- Zerbitzuak monitorizatu eta intzidenteei erantzuteko prozedurak definitu
- Zaurgarritasunak konpondu eta intzidenteetatik ikasi

Neurketa eta etengabeko hobekuntza

- Detekzio- eta konponketa-denborak neurtu, bai eta zain dauden aurkikuntzak ere
- Faltsu positiboak berrikusi eta kontrolak doitu
- Emaitzak hobekuntzak lehenesteko erabili, ez soilik entregak blokeatzeko
- Erantzukizunak eta ikasitakoa taldeen artean partekatu